

TAREA BRS03

Configuración de sistemas de control de acceso y autenticación de personas

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Tarea de investigación aplicada	3
Respuestas 1	3
Apartado 2: Prueba de comportamiento ante eventos poco comunes	8
Respuestas 2	8
Apartado 3: Diseño de una propuesta de autenticación para un entorno real	10
Respuestas 3	10

Detalles de la tarea de esta unidad

Caso práctico

El director de seguridad de una empresa tecnológica ha detectado que, aunque los empleados conocen los tipos de factores de autenticación, muchos no comprenden realmente cómo funcionan en la práctica, qué vulnerabilidades reales presentan, ni cómo elegir el mecanismo adecuado según el contexto. Te ha pedido un informe que incluya investigación aplicada, pruebas prácticas y propuestas de mejora para el plan interno de autenticación reforzada.

Apartado 1: Tarea de investigación aplicada

Una vez conocidos los diferentes factores de autenticación, deberás realizar una investigación en profundidad que incluya:

1. Identificación de tres servicios reales

Selecciona tres servicios que tú utilices (correo, cloud, red social, repositorio, etc.) y explica:

- Qué tipos de factores implementan realmente (no teoría).
- Cómo gestionan el proceso de recuperación de la cuenta.
- Qué ventajas aportan frente a mecanismos convencionales.
- Qué inconvenientes presentan en el uso diario.

Debes incluir al menos una captura de pantalla propia del menú o proceso de activación, evitando mostrar datos personales.

(La ausencia de capturas invalida el apartado.)

2. Análisis de un incidente documentado de seguridad

Investiga un caso real en el que haya fallado un mecanismo 2FA o MFA (phishing sofisticado, SIM swapping, bypass biométrico, prompt bombing...).

Debes explicar:

- Qué mecanismo falló.
- Qué vulnerabilidad se explotó.
- Si consideras que hoy podría repetirse.
- Qué habrías diseñado tú para evitarlo.

Debes aportar la fuente del caso real y un análisis personal, no una descripción genérica.

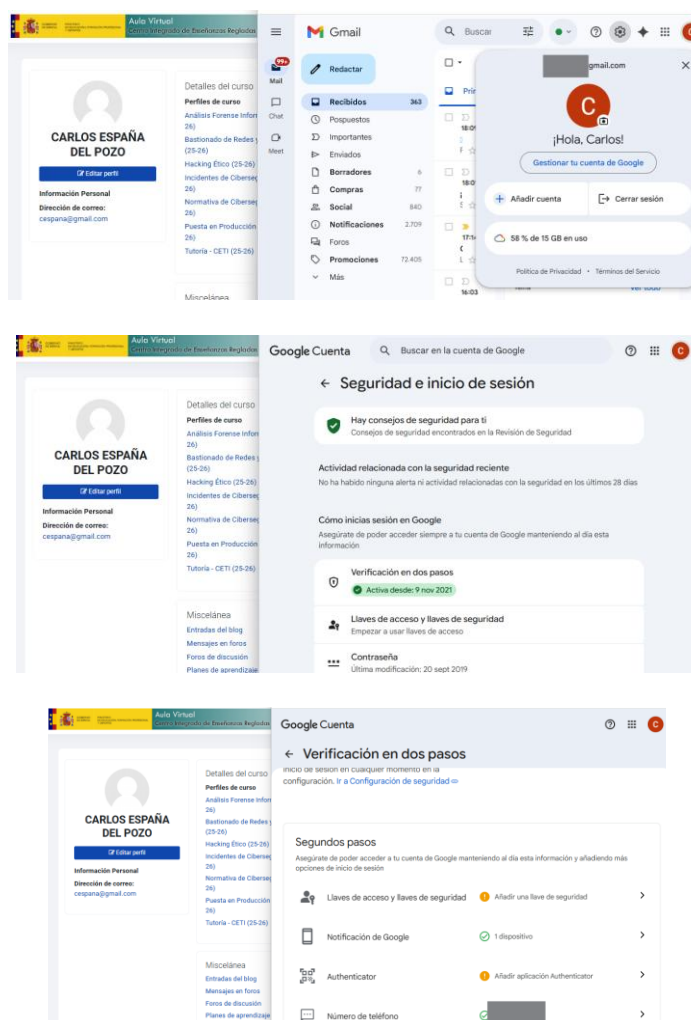
Respuestas 1

Vamos a mostrar tres servicios reales que utilizo y que tienen métodos de autenticación de MFA:

- Correo -> GMAIL
- RRSS -> LinkedIn
- Repositorio -> Github

Gmail permite varios tipos de factores de autenticación:

- Usuario y Contraseña (Primer factor)
- Llaves de acceso y seguridad
- Notificación de Google (Push)
- Authenticator (códigos TOTP)
- SMS / teléfono
- Codigos de verificación alternativos



Google ofrece un sistema automatizado de recuperación en el que te solicita:

- Última contraseña que recuerdes
- Código enviado a correo alternativo
- Código SMS al móvil de recuperación
- Verificación del dispositivo habitual

Para mi, personalmente encuentro las siguientes ventajas en la seguridad de Gmailde MFA:

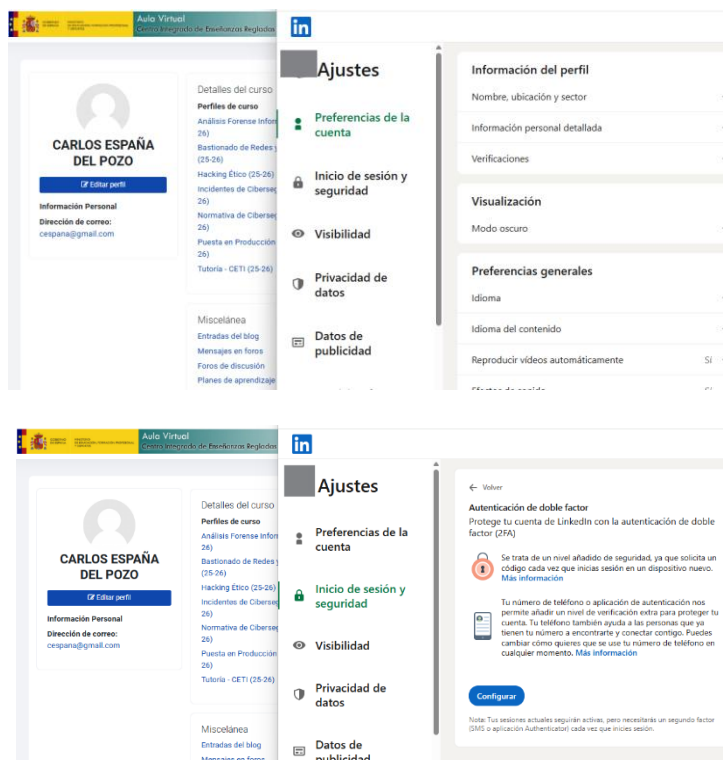
- Mucho más seguro que solo usuario y contraseña.
- En muchos casos se permite bloquear accesos sospechosos
- Es compatible con llaves físicas
- Detección automática de actividad sospechosa

Pero los inconvenientes podrían ser:

- Dependencia del móvil
- Configuración compleja para usuarios no expertos

Linkedin permite varios tipos de factores de autenticación:

- Usuario y Contraseña (Primer factor)
- Authenticator (códigos TOTP)
- Teléfono



LinkedIn permite recuperar la cuenta mediante estos metodos:

- Correo electrónico
- Teléfono móvil
- Verificación CAPTCHA
- Identificación de actividad reciente

En este caso, encuentro las siguientes ventajas en la seguridad de LinkedIn con MFA:

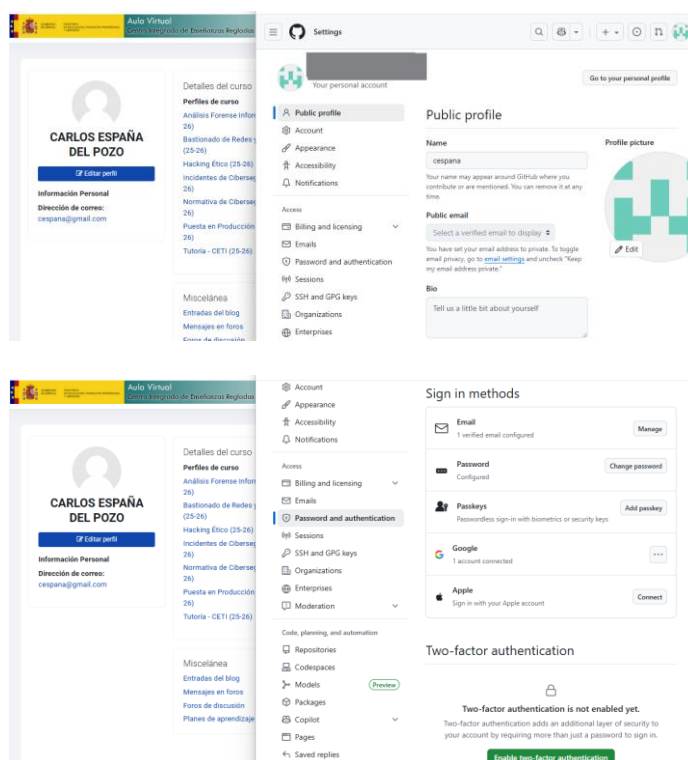
- Mucho más seguro que solo usuario y contraseña.
- En muchos casos se permite bloquear accesos sospechosos
- Es compatible con llaves físicas
- Detección automática de actividad sospechosa

Pero los inconvenientes podrían ser:

- Sin llave física
- Dependencia de la cuenta de correo

Github permite varios tipos de factores de autenticación:

- Usuario y Contraseña (Primer factor)
- Passkeys (seguridad passwordless)
- SMS
- Authenticator (códigos TOTP)



Github nos permite recuperar la cuenta mediante estos metodos:

- Codigos de recuperación
- Dispositivo verificado.
- Correo verificado.

Para mi, personalmente encuentro las siguientes ventajas en la seguridad de Gmailde MFA:

- Seguridad alta
- Uso de passkeys
- Es compatible con llaves físicas

Pero los inconvenientes podrían ser:

- Dependencia del móvil
- Configuración compleja para usuarios no expertos

Vamos a analizar un incidente documentado de seguridad

Una banda de ciberdelincuentes fue desarticulada por la Policía Nacional tras detectar que utilizaban SIM swapping —junto con phishing/smishing— para vaciar cuentas bancarias de sus víctimas.



Falló el factor de autenticación secundaria basado en SMS: los atacantes consiguieron duplicar la SIM de la víctima y recibían los códigos SMS.

Los atacantes suplantaban al cliente usando datos personales (obtenidos por phishing u otros medios) y convencían a la operadora para entregar una SIM nueva con su número. Esa operación, les permitía controlar los SMS de la víctima.

Hoy en día este tipo de ataque podría repetirse, por la debilidad de el 2Fa mediante SMS. Mi recomendación sería eliminar o desincentivar el 2FA por SMS o implementar un sistema de verificación reforzado para las operadoras.

Bajo mi punto de vista personal, este tipo de engaños refuerza la idea de que los métodos seguros de autenticación pasan por los MFA o los métodos mas modernos webauth que obligan a tener un dispositivo personal o biometría para la autenticación, además de continuar con campañas de concienciación de ciberseguridad.

Apartado 2: Prueba de comportamiento ante eventos poco comunes

Simula estas tres situaciones:

- Acceso desde otro país mediante VPN.
- Introducción repetida de contraseñas incorrectas.
- Intento de acceso desde un dispositivo desconocido.

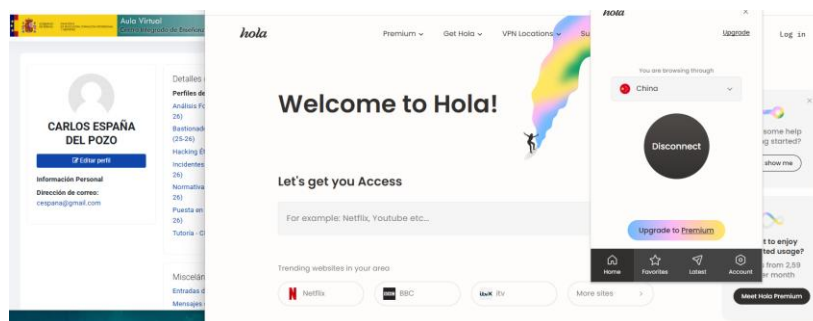
Para cada escenario:

- Describe la reacción del sistema.
- Indica si te parece suficiente y por qué.
- Añade observaciones personales que no se puedan deducir sin hacer la prueba.

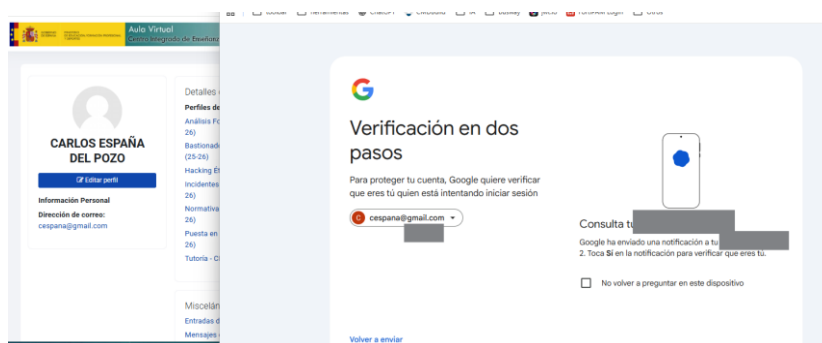
Respuestas 2

Vamos a simular las situaciones indicadas con los sistemas de Gmail y de LinkedIn

Instalando una VPN gratuita como holaVPN intentamos acceder desde china a nuestro correo.



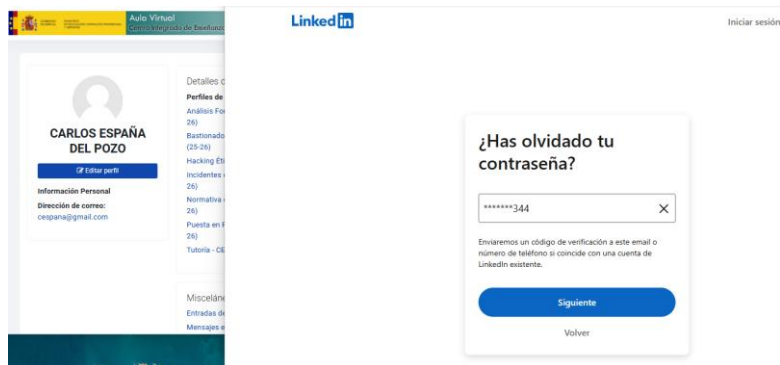
Nos solicita el doble factor de autenticación, en realidad para mi es suficiente, puesto que al solicitar el segundo factor (en este caso la autorización por mi dispositivo, sería un método seguro para evitar incidentes.



Si en LinkedIn metemos una password incorrecta durante varios intentos.

Nos solicita el doble factor de autenticación del tño para restablecer ontraseña.

En principio si hemos configurado correctamente nuestro 2FA con el teléfono, seria un método para evitar ataques de diccionario.



Si intentamos conectar con una ventana de incognito para simular otro dispositivo en Gmail, nos solicita un segundo factor de autenticación.

Una vez mas podemos indicar que es un método seguro para evitar accesos no autorizados desde dispositivos desconocidos.



Apartado 3: Diseño de una propuesta de autenticación para un entorno real

Selecciona o inventa un entorno profesional (empresa, colegio, administración, clínica, etc.) y define:

- Tipos de usuarios.
- Dispositivos utilizados.
- Datos sensibles que gestionan.
- Riesgos más probables.

Selecciona o inventa un entorno profesional (empresa, colegio, administración, clínica, etc.) y define:

Tipos de usuarios.

Dispositivos utilizados.

Datos sensibles que gestionan.

Riesgos más probables.

A partir de ello, diseña una propuesta completa de autenticación que incluya:

Qué factores usaría cada tipo de usuario.

Qué factores no usarías y por qué.

Cómo sería la política de recuperación de acceso.

Un diagrama sencillo del proceso de autenticación (hecho por ti, a mano o con herramienta).

Respuestas 3

Mi entorno profesional simulado consiste en una clínica privada de tamaño medio, especializada en medicina general y diagnósticos, con aproximadamente 40 empleados y una base de datos con unos 5.000 pacientes. El sistema principal es una aplicación web interna que gestiona citas, historias clínicas, resultados de pruebas diagnósticas y facturación.

Este entorno requiere un alto nivel de seguridad, ya que maneja información médica especialmente sensible.

Tipos de usuarios

Médicos
Enfermeros/as
Administración
Dirección

Técnicos de laboratorio
Pacientes

Tipos de dispositivos

Ordenadores de sobremesa en la clínica
Portátiles corporativos
Tablets utilizadas por los médicos en consulta.
Terminales específicos en laboratorio y recepción.
Smartphones personales de los pacientes.

Datos sensibles gestionados

Historias clínicas completas.
Diagnósticos y tratamientos.
Resultados de análisis y pruebas.
Datos personales (DNI, dirección, teléfono, correo).
Información bancaria para pagos.
Informes médicos confidenciales.

Estos datos se consideran de alta sensibilidad según el RGPD y la normativa sanitaria.

Riesgos

Robo o filtración de credenciales de acceso por phishing.
Acceso no autorizado desde dispositivos externos o robados.
Suplantación de identidad de pacientes o empleados.
Accesos indebidos por parte de empleados internos.
Pérdida o robo de dispositivos sin protección adecuada.
Ataques de fuerza bruta sobre el portal web de pacientes.

En base a esta información diseño la siguiente propuesta de autenticación dividida por grupos de usuarios:

Personal médico y dirección

- Contraseña fuerte
- Segundo factor obligatorio (app autenticadora o certificado)
- Bloqueo tras varios intentos fallidos

Personal administrativo y técnico

- Contraseña fuerte
- Segundo factor (app autenticadora)
- Acceso solo desde la red interna o con VPN

Pacientes

- Contraseña fuerte
- Código por correo o app autenticadora

No usaríamos los siguientes factores de autenticación:

- SMS: Peligroso (SIM swapping)
- Preguntas secretas: Fáciles de adivinar
- Solo contraseña: Insuficiente

La recuperación de los accesos los dividiría en personal y pacientes de la siguiente manera:

Empleados

- Solo el departamento de sistemas puede resetear
- Verificación de identidad
- Todo queda registrado

Pacientes

- Recuperación por email + datos personales
- En casos importantes, presencial

El flujo básico de acceso sería el siguiente:

1. Usuario + contraseña
2. Segundo factor
3. Verificación de dispositivo/ubicación
4. Acceso según rol (RBAC)

Si falla el proceso, denegación de acceso y posible bloqueo.